

KRİPTOQRAFIYA KURSU

Mühazirə 27

Kriptoanaliz və Yan Kanal Hücumları

Bu mühazirə kriptoanalizin əsas növlərini (diferensial, xətti), tam axtarış hücumlarını, yan kanal hücumlarını (vaxt, güc, elektromaqnit, keş, xəta inyeksiyası hücumları) və onlara qarşı müdafiə üsullarını əhatə edir.

July 31, 2026

Contents

1	Mühazirənin məqsədləri	3
2	Giriş	3
	I hissə: Alqoritmik kriptanaliz	6
3	Kriptanaliz və Əsas Hücüm Metodologiyaları	6
3.1	1. Riyazi və Struktur Kriptanaliz Metodları	6
3.2	2. Yan Kanal Hücumları (Fiziki Hücumlar)	7
3.3	3. Müdafiə Üsulları	8
4	Tam axtarış hücumu	9
5	Diferensial Kriptanaliz	9
5.1	Kritik Anlayış: Raund Açarının XOR ilə İxtisarı	10
5.2	S-Qutusu Asimmetriyası və Diferensial Paylanma Cədvəli (DDT)	10
5.3	Riyazi İş Prinsipi və Mərhələləri	11
6	Xətti Kriptanaliz	11
6.1	Riyazi İş Prinsipi və Mərhələləri	12
6.2	Meyllilik Dərəcəsinin Analitik Tapılması Metodologiyası	13
6.3	Diferensial və Xətti Kriptanalizin Müqayisəli Təhlili	14
	II hissə: Realizasiya və fiziki sızıntılar	15
7	Yan Kanal Hücumlarına Giriş	15
8	Vaxt Hücumu (Vaxt Hücumu)	16
8.1	İş Prinsipi	16
8.2	RSA Alqoritminə qarşı Vaxt Hücumu	16
8.3	Nəzəri Müdafiə Strategiyaları	17
9	Enerji Analizi (Enerji Analizi)	17
9.1	SPA (Simple Enerji Analizi — Sadə Enerji Analizi)	17
9.2	DPA (Differential Enerji Analizi — Diferensial Enerji Analizi)	18
9.3	Nəzəri Müdafiə Strategiyaları	18
10	Elektromaqnit Hücumları (EMA)	19
11	Keş Yaddaş Hücumları (Keş Hücumları)	19
12	Xəta İnyeksiyası Hücumları (Xəta İnyeksiyası Hücumları)	20
12.1	DFA: diferensial xəta analizi	20
12.2	RSA-CRT Alqoritminə qarşı Bellcore Xəta İnyeksiyası Hücumu	20
12.3	Nəzəri Müdafiə Strategiyaları	21

13 Digər Yan Kanal Hücumları	21
13.1 Akustik Kriptoanaliz	21
13.2 Soyuq yükləmə hücumu	22
13.3 Optik Hücumlər	22
14 Yan Kanal Hücumlarına Qarşı Sistem Səviyyəli Müdafiə	22
14.1 Aparat Səviyyəsində Müdafiə	22
14.2 Proqram Səviyyəsində Müdafiə	23
14.3 Kriptoqrafik Protokol Səviyyəsində Müdafiə	23
15 Yan Kanal Hücumlarının Müqayisəli Analizi	23
16 Praktiki Layihələndirmə Təvsiyələri	25
17 Nümunə Məsələlər və Çalışmalar	26
18 Müəllim üçün cavab açarı	27
19 Xülasə və Yekun Nəticələr	28

1 Mühazirənin məqsədləri

Bu mühazirəni müvəffəqiyyətlə başa vurduqdan sonra tələbələr:

- Tam axtarış hücumunun (*brute-force*) mürəkkəbliyini açar ölçüsündən hesablamağı, diferensial və xətti kriptanalizin məlumat modellərini fərqləndirməyi (Biham and Shamir, 1993; Matsui, 1994a);
- DDT¹ və xətti yaxınlaşma nəticələrini ehtimal və kənarlaşma (*bias*) dili ilə şərh etməyi;
- Alqoritmik (riyazi) kriptanaliz ilə icra müddəti, enerji sızması, keş yaddaş, elektromaqnit şüalanma və xəta inyeksiyası kimi kənar kanal müşahidələrini fərqləndirməyi (Kocher, 1996; Kocher et al., 1999);
- Verilmiş kənar kanal izindən və ya səhv RSA-CRT² imzasından informasiya sızmasının səbəbini müəyyənləşdirməyi (Boneh et al., 1997);
- Verilmiş təhdid modelinə uyğun olaraq sabit-zamanlı kodlaşdırma (*constant-time execution*), maskalama (*masking*), korlaşdırma (*blinding*) və çıxışın doğrulanması müdafiə kombinasiyalarını elmi şəkildə əsaslandırmağı bacaracaqlar (Mangard et al., 2007).

Kurs xəritəsi və terminologiya kanonu

Əvvəlki mühazirə: 17-ci mühazirədə Montqomeri nərdivanının (*Montgomery ladder*) təkbaşına sabit-zaman zamanəti vermədiyi qeyd olunmuş, 19–26-cı mühazirələrdə penetrasiyaya davamlı təhlükəsiz protokollar təhlil edilmişdi.

Cari mühazirə: Əvvəlcə alqoritmik (kriptografik), daha sonra implementasiya/fiziki (kənar kanal) hücum modellərini iki müstəqil hissədə araşdırırıq.

Növbəti mühazirə: 28-ci mühazirə klassik açıq açar fərziyyələrinə kvant hücumlarını və PQC^a keçid mexanizmlərini təhlil edəcək.

Terminologiya kanonu: *enerji analizi (power analysis); xəta inyeksiyası (fault injection); raund açarının XOR ilə ixtisarı.*

^aPQC (*Post-Quantum Cryptography* — Kvantdan Sonrakı Kriptografiya): Kvant kompüterlərinin Şor (Shor) alqoritmı ilə sındıra bilməyəcəyi (məsələn, qəfəs əsaslı) yeni nəsil kriptografik alqoritmlər kompleksi.

2 Giriş

Kriptografik sistemlərin müasir təhlükəsizlik paradigması iki əsas sütuna söykənir: **alqoritm**in **riyazi (nəzəri) dayanıqlığı** və **implementasiyanın təhlükəsizliyi**. Təhlükəsizlik modelində güclü qəbul edilən alqoritm real aparat və ya proqram təminatında icra olunarkən vaxt, enerji, keş və başqa müşahidə olunan siqnallar sızdırı bilər.

¹DDT (*Difference Distribution Table* — Fərqlərin Paylanması Cədvəli): S-boks (*Substitution-box*) kimi qeyri-xətti elementlərin giriş fərqlərinin çıxış fərqlərinə necə çevrildiyini və diferensial hücumlar üçün ehtimalları göstərən cədvəl.

²RSA-CRT (*Rivest-Shamir-Adleman with Chinese Remainder Theorem* — Çin Qalıq Teoremi ilə RSA): RSA rəqəmsal imzalama və deşifrə etmə əməliyyatlarını 3-4 dəfə sürətləndirmək üçün modul hesablamalarını p və q sadə ədədləri üzrə ayrı-ayrı aparən alqoritmik reallaşdırma.

Bu mühazirə çərçivəsində kriptografik sistemlərin riyazi zəifliklərini araşdıran klassik **kriptoanalizi** və alqoritmlərin icrası zamanı ortaya çıxan fiziki sızıntılardan (vaxt, enerji sərfiyyatı, elektromaqnit şüalanma) yararlanan **yan kanal hücumlarını** müzakirə edəcəyik. Tələbələr həm şifrlərin riyazi olaraq necə təhlil edildiyini, həm də qara qutu modelindən kənara çıxan real hücumların mexanizmlərini öyrənəcəklər.

Müzakirə Ediləcək Əsas Suallar

- Kriptanaliz nədir və o, hansı klassik hücum modelləri^a və metodologiyalarına bölünür?
- Diferensial kriptanaliz^b blok şifrələrə necə tətbiq olunur?
- Xətti kriptanaliz^c alqoritmlərin qeyri-xətti elementlərinin xətti yaxınlaşması prinsipinə necə əsaslanır?
- Tam axtarış^d hücumunun riyazi mürəkkəblik hədləri və iş amili necə müəyyən edilir?
- Kənar kanal hücumları^e nədir və onlar nə üçün ənənəvi alqoritmik kriptanaliz metodlarından daha effektivdir?
- Vaxt hücumu (*timing attack*) proqram kodundakı şərti budaqlanmalar və şərti icra müddəti vasitəsilə gizli açarı necə aşkar edir?
- Sadə (SPA^f) və diferensial (DPA^g) enerji analizi hücumlarının fundamental fərqləri nələrdir?
- Keş hücumları^h müasir prosessorların mikroarxitekturasından necə sui-istifadə edir?
- Xəta inyeksiyası hücumlarıⁱ riyazi hesablama zəncirini pozmaqla açarı necə əldə edir?
- Bu hücum növlərinə qarşı hansı proqram (sabit-zamanlı kod, maskalama, korlaşdırma) və aparat səviyyəli müdafiə üsulları mövcuddur?

^aKlassik kriptanalitik hücum modelləri: Yalnız şifrəli mətn (*ciphertext-only*), məlum açıq mətn (*known-plaintext*), seçilmiş açıq mətn (*chosen-plaintext*) və seçilmiş şifrəli mətn (*chosen-ciphertext*) hücumları.

^bDiferensial kriptanaliz: Açıq mətn cütliklərinin fərqlərinin (*input differences*) şifrəli mətn fərqlərinə (*output differences*) keçmə ehtimallarını (DDT vasitəsilə) analiz edərək raund açarlarını əldə edən metod.

^cXətti kriptanaliz: Mətn bitləri, şifrəli mətn bitləri və açar bitləri arasında xətti bərabərliklər (yaxınlaşmalar) quraraq kənarlaşma (*bias*) ehtimalı əsasında açarı aşkar edən metod.

^dTam axtarış (*brute-force search*): Mümkün olan bütün açar fəzasını sırayla yoxlamaqla doğru açarı tapan riyazi hücum metodu.

^eKənar kanal hücumları (*side-channel attacks*): Alqoritmin riyazi zəifliyinə yox, onun fiziki reallaşdırılması zamanı yaranan fiziki parametrlərə (icra müddəti, enerji sərfi, EM şüalanma, keş gecikmələri) əsaslanan hücumlar.

^fSPA (*Simple Power Analysis* — Sadə Enerji Analizi): Bir və ya bir neçə osilloqram kəsiyini birbaşa vizual olaraq təhlil etməklə kriptografik əməliyyatları və açar bitlərini oxuma metodu.

^gDPA (*Differential Power Analysis* — Diferensial Enerji Analizi): Çoxsaylı enerji göstəricilərinin statistik təhlili (məsələn, Pirsan korrelyasiyası) vasitəsilə küy dərəcəsini azaldıb gizli açarı müəyyənləşdirən metod.

^hKeş hücumları (*cache attacks*): Prosessorun RAM və Keş yaddaşları arasındakı giriş vaxtı fərqliliyindən (Flush+Reload, Prime+Probe) istifadə edərək gizli açarla bağlı yaddaş ünvanlarını oxuma texnikası.

ⁱXəta inyeksiyası hücumları (*fault injection attacks*): Kriptografik hesablama gedən anda mikrosxemə gərginlik impulsu, saat tezliyi dəyişikliyi və ya lazer şüası vurmaqla xətalı nəticə alıb (DFA) açarı hesablama texnikası.

I hissə: Alqoritmik kriptanaliz

3 Kriptanaliz və Əsas Hücum Metodologiyaları

Kriptanaliz — şifrələmə alqoritmlərinin riyazi, struktur və ya fiziki zəifliklərini araşdıraraq, gizli açarı və ya açıq mətni əldə etmək məqsədi daşıyan elm sahəsidir. Müasir kriptanaliz fundamental olaraq iki böyük kateqoriyaya bölünür: alqoritmin riyazi modelini hədəf alan **Riyazi (Nəzəri) Kriptanaliz** və alqoritmin icra olunduğu fiziki mühiti hədəf alan **Yan Kanal Hücumları (Yan Kanal Hücumları)**.

Aşağıda, təhlükəsizlik analizlərində istifadə olunan əsas üsulların qısa və fundamental izahı verilmişdir:

3.1 1. Riyazi və Struktur Kriptanaliz Metodları

- **Klassik hücum modelləri:** Aşağıdakı modellər hücumçuya verilən sorğu və məlumat imkanlarını təsvir edir; onlar universal xərc sıralaması deyil. Konkret hücumun verilən, zaman və yaddaş mürəkkəbliyi seçilmiş primitivdən və təhlükəsizlik anlayışından asılıdır:
 1. *Yalnız şifrəli mətn:* Hücumçu şifrəli mətnləri müşahidə edir, lakin uyğun açıq mətnə və sorğu mənbəyinə malik deyil.
 2. *Məlum açıq mətn:* Hücumçu bəzi uyğun (P_i, C_i) cütlərini bilir.
 3. *Seçilmiş açıq mətn (CPA):* Hücumçu seçdiyi açıq mətnlər üçün şifrələmə nəticəsini ala bilir; diferensial kriptanaliz çox vaxt bu imkanla təqdim olunur.
 4. *Seçilmiş şifrəli mətn (CCA):* Hücumçu təhlükəsizlik oyununda icazə verilən seçilmiş şifrəli mətnlər üçün deşifrə sorğusu verə bilir. Adaptiv CCA qaydaları sınaq mətninin özünü soruşmağa icazə vermir.

Primitiv və sxem fərqi:

Daha güclü sorğu imkanına (*oracle accessibility*) malik hücumçu ən azı əvvəlki hücum modelindəki strategiyaları təkrar icra edə bilər; lakin bu, uğurlu hücumun mürəkkəbliyinin mütləq azalacağı və ya real ssenarilər üzrə monoton ehtimal paylanması yaradacağı mənasına gəlmir.

CPA^a/CCA^b təhlükəsizlik xassələri doldurma (*padding*), nons^c autentifikasiya teqi və xəta emalı davranışı daxil olmaqla **bütöv şifrələmə sxemi** üçün təyin edilir.

İşlənmemiş AES^d blok şifrini birbaşa “CCA-davamlı AES” demək terminoloji baxımdan düzgün deyildir; məsələn, müvafiq AEAD^e sxemi düzgün nons istifadəsi və tətbiq qaydaları çərçivəsində CCA tipli bütövlük və məxfilik tələblərini təmin edir.

^aCPA (*Chosen-Plaintext Attack* — Seçilmiş Açıq Mətn Hücumu): Hücumçunun istədiyi açıq mətni seçib ona uyğun şifrəli mətni əldə edə bildiyi hücum modeli.

^bCCA (*Chosen-Ciphertext Attack* — Seçilmiş Şifrəli Mətn Hücumu): Hücumçunun deşifrələmə orakuluna sorğu göndərərək istədiyi şifrəli mətnin (seçilmiş hədəf mətni istisna olmaqla) deşifrə olunmuş açıq mətnini əldə edə bildiyi ən güclü hücum modeli.

^cNons (*Nonce* — *Number used Once*): Eyni açarla şifrələnən hər bir mesaj üçün yalnız bir dəfə istifadə olunan təsadüfi və ya unikal dəyər.

^dAES (*Advanced Encryption Standard* — Qabaqcıl Şifrələmə Standartı): 128-bitlik blok ölçüsünə malik simmetrik blok şifrə primitivi.

^eAEAD (*Authenticated Encryption with Associated Data* — Əlaqəli Məlumatlı Autentifikasiyalı Şifrələmə): Məlumatın həm məxfiliyini, həm də autentifikasiyasını (bütövlüyünü) eyni anda təmin edən şifrələmə sxemi rejimi (məsələn, AES-GCM).

- **Tam axtarış hücumu:** Alqoritmın daxili riyaziyyatına baxmadan mümkün açarları yoxlayır. İdeal n -bit açarda ən pis halda 2^n , orta hesabla təxminən 2^{n-1} sınaq tələb olunur; 128-bit səviyyə cari klassik resurslarla praktik ölçətməz sayılır, lakin sistemin real təhlükəsizliyi protokol və reallaşdırmadan da asılıdır.
- **Diferensial Kriptanaliz:** Seçilmiş açıq mətn hücumudur. Giriş mətnlərinin xüsusi olaraq seçilmiş fərqlərinin ($\Delta P = P \oplus P'$), şifrələmə raundları boyunca irəliləyərək çıxışda hansı fərqləri (ΔC) yaratma ehtimalını (stoxastik cığırlları) izləyir. Qeyri-xətti S-qutularının daxili qeyri-bərabər paylanma ehtimallarından, yəni **diferensial paylanma cədvəlindən** (DDT) istifadə edərək sonuncu raundun açarını statistik səsvermə ilə tapır.
- **Xətti kriptanaliz:** Məlum açıq mətn hücumudur. S-qutusunun qeyri-xətti daxili strukturu xətti tənliklərlə yaxınlaşdırmağa əsaslanır. Giriş bitləri ilə çıxış bitlərinin müəyyən xətti kombinasiyalarının ($P_{i_1} \oplus \dots \oplus C_{j_1} \oplus \dots = K_{m_1}$) doğru olma ehtimalının $1/2$ -dən fərqlənmə dərəcəsini ölçərək gizli açar bitlərini süzüb çıxarır.

3.2 2. Yan Kanal Hücumları (Fiziki Hücumlar)

Ənənəvi kriptanaliz şifri “kağız üzərində” mükəmməl riyazi obyekt kimi görür. Yan kanal hücumları isə şifrini icra olunduğu real mikrosxemin, prosessorun fiziki sızıntılarını ölçür.

- **Yan Kanal Hücumlarının Effektivliyi:** Yan kanal alqoritmın nəzəri açar-axtarış sərhədindən yan keçə bilər, lakin hücumun uğuru sızıntı modeli, ölçmə keyfiyyəti, giriş imkanı, iz sayı və əks-tədbirlərdən asılıdır. Nəticə bir neçə izdən uzun laboratoriya kampaniyasına qədər dəyişə bilər.

- **Vaxt Hücumu (*Vaxt Hücumu*):** Gizlidən asılı budaq, yaddaş müraciəti və dəyişən müddətli əməliyyatların yaratdığı zaman paylanmalarından istifadə edir. Kifayət qədər signal, ölçmə və uyğun model olduqda açar barədə statistik məlumat bərpa oluna bilər.
- **Enerji Analizi Hücumları (SPA və DPA):**
 - *Sadə Enerji Analizi (SPA)*: Kriptografik cihazın cəmi bir və ya bir neçə şifrələmə zamanı xərclədiyi elektrik enerjisinin qrafikinə (osilloqramma) birbaşa vizual baxmaqla (məsələn, RSA alqoritmində kvadrat yüksəltmə və vurma əməliyyatlarının fərqli enerji xərcləməsini görməklə) açarı oxuyur.
 - *Diferensial Enerji Analizi (DPA)*: Çoxsaylı enerji izləri, sızıntı hipotezi və statistik testlə açar namizədlərini fərqləndirir. Tələb olunan iz sayı cihaz, model, küy və əks-tədbirlərdən asılıdır.
- **Keş Hücumları:** Müasir prosessorların sürəti artırmaq üçün istifadə etdiyi keş yaddaşı arxitekturasını hədəf alır. S-qutularının yaddaşda yerləşdiyi ünvanların keş yüklənib-yüklənməməsinə görə yaddaşa müraciət vaxtını ölçür (*Prime+Probe* və ya *Flush+Reload* üsulları ilə) və bununla da gizli açarın hansı S-qutusu indeksindən istifadə etdiyini ifşa edir.
- **Xəta İnyeksiyası Hücumları:** Şifrələmə icra olunan anda cihaza fiziki müdaxilə (məsələn, lazer şüası, gərginlik və ya temperatur sıçrayışı) etməklə registrlərdəki bitləri qəsdən dəyişdirir ($1 \rightarrow 0$ və ya $0 \rightarrow 1$). Səhv hesablanmış şifrəli mətnlə düzgün şifrəli mətni riyazi olaraq müqayisə edərək xətanın baş verdiyi raunddakı açar bitlərini tapır.

3.3 3. Müdafiə Üsulları

Bu hücumlardan qorunmaq üçün həm proqram, həm də aparat səviyyəsində xüsusi əks-tədbirlər görülür:

1. **Sabit Zamanlı Kod :** Gizlidən asılı budaqlar, yaddaş ünvanları və dəyişən sayda əməliyyatlar aradan qaldırılır. Mənbə kodunun budaqsız görünməsi kifayət deyil: kompilyator çıxışı, mikroarxitektura və hədəf platforma ayrıca yoxlanmalıdır.
2. **Maskalama :** Həssas aralıq dəyərlər təsadüfi paylara bölünür və əməliyyatlar həmin paylar üzərində aparılır. Düzgün maskalama seçilmiş sızıntı modelində aşağı dərəcəli korrelyasiyanı azalda bilər; təsadüfilik keyfiyyəti, xəta impulsar və yüksək dərəcəli hücumlar nəzərə alınmalıdır.
3. **Nəticənin Doğrulanması (*Result Verification*):** Seçilmiş xəta modelinə (*fault model*) uyğun olaraq invariantlar, artıq hesablamalar (*redundant computation*) və ya birbaşa çıxışın doğrulanması tətbiq edilir. Məsələn, RSA-CRT imzası xaricə ötürülməzdən əvvəl mütləq açıq açarla doğrulanmalıdır. Müdafiə mexanizminin (*countermeasure*) özü də xəta impulsarı (*glitch*)³ vasitəsilə yan keçilmə (*bypass*) və kənar kanal sızması baxımından qiymətləndirilməlidir.

³Xəta impulsu (*glitch*): Mikrosxemə vurulan anlıq gərginlik, saat tezliyi dəyişikliyi və ya lazer müdaxiləsi vasitəsilə proqram axınına pozan fiziki müdaxilə.

4 Tam axtarış hücumu

Tərif 4.1 (Tam axtarış hücumu). *Tam axtarış hücumu — istifadə olunan kriptografik alqoritmın daxili strukturuna və riyazi xüsusiyyətlərinə baxılmadan, mümkün olan bütün açar fəzasının ardıcıl və ya paralel şəkildə yoxlanılması vasitəsilə doğru açarın tapılması metodudur (Stinson and Paterson, 2018).*

Alqoritmik mürəkkəbliik: Simmetrik kriptografiyada n -bit uzunluğunda bir açar üçün tam axtarış hücumunun zaman mürəkkəbliyi **ən pis hal** ssenarisində $\mathcal{O}(2^n)$, **orta hal** ssenarisində isə $\mathcal{O}(2^{n-1})$ bərabərdir.

Nümunə 4.1 (DES-in mühəndislik üsulu ilə sındırılması). *DES alqoritmı 56-bitlik açar fəzasına (2^{56} mümkün açar) malikdir. 1998-ci ildə **Elektron Sərhəd Fondu (EFF)** tərəfindən **təxminən 250,000 ABŞ dolları** büdcə ilə xüsusi layihələndirilmiş və paralel ASIC prosessorlardan ibarət olan Deep Crack aparat təminatı hazırlanmışdır. Bu maşın cəmi 22 saat 15 dəqiqə ərzində bütün açar fəzasını yoxlayaraq DES-i uğurla sındırmış və o dövr üçün böyük bir sensasiyaya səbəb olmuşdur (ElectronicFrontierFoundation, 1998).*

Nümunə 4.2 (FPGA əsaslı ucuz kütləvi hücum: COPACOBANA). *EFF-in uğurundan sonra, 2006-cı ildə Almanıyanın Boxum və Saarlend universitetlərinin alimləri tərəfindən tamamilə fərqli bir yanaşma ilə **COPACOBANA** adlı xərc baxımından optimallaşdırılmış paralel kod-sındıran xüsusi aparat təminatı layihələndirildi.*

*Deep Crack təxminən 250,000 ABŞ dolları büdcə ilə və yalnız bir məqsəd üçün istehsal olunmuş ASIC mikrosxemlərinə əsaslandığı halda, COPACOBANA layihəsində yenidən proqramlaşdırıla bilən və bazarda asanlıqla tapılan 120 ədəd ucuz **FPGA** (sahədə proqramlaşdırılan qapı matrisi) çipindən istifadə edildi:*

- **İqtisadi Səmərəlilik:** *Cəmi 10,000 ABŞ dolları (təxminən 8,000 Avro) büdcə ilə hazırlanan bu maşın, xüsusi dövlət agentliklərinin milyon dollarlıq superkompüterlərinin gücünü akademik laboratoriyalara gətirdi (EFF-dən 25 dəfə daha ucuz).*
- **Sürət Göstəricisi:** *COPACOBANA saniyədə 30 milyarddan çox DES açarını yoxlamaq gücü sayəsində, 2^{56} ölçülü bütün DES açar fəzasını ortalama **9 gün daxilində** (maksimum 17 gün) tamamilə skan edərək gizli açarı tapmağı bacarırdı.*

Bu layihə kriptografiya dünyasına sübut etdi ki, blok uzunluğu və açar fəzası kiçik olan şifrlər (məsələn, 56-bit) təkcə dövlətlər tərəfindən deyil, kiçik büdcəli haker qrupları və ya akademik mühitlər tərəfindən də aparat təminatı səviyyəsində asanlıqla sındırıla bilər.

Yuxarıda qeyd olunan hər iki mühəndislik nümunəsi (EFF Deep Crack və COPACOBANA) rəsmi dövlət standartı olan DES alqoritmının praktiki olaraq təhlükəsizliyini itirdiyini qəti şəkildə sübut etdi. Bu isə öz növbəsində müasir tələblərə cavab verən yeni bir qlobal blok şifrələmə standartının yaradılmasını zəruri etdi. Nəticədə, ABŞ-ın NIST qurumu tərəfindən elan edilən beynəlxalq müsabiqə vasitəsilə Rijndael alqoritmı qalib seçilərək **AES** təkmil şifrələmə standartı kimi qəbul edildi.

5 Diferensial Kriptoanaliz

Diferensial kriptoanaliz — **Eli Biham** və **Adi Şamir** tərəfindən 1990-cı ildə irəli sürülmüş, xüsusilə blok şifrlərə qarşı tətbiq olunan və **seçilmiş açıq mətn** modelinə əsaslanan sistemli hücum üsuludur (Biham and Shamir, 1993).

Cədvəl 1: Müxtəlif alqoritmlərin tam axtarış mürəkkəbliyi hədləri

Alqoritm	Açar Uzunluğu	Zaman Mürəkkəbliyi	Təhlükəsizlik Statusu
DES	56-bit	2^{56}	Sındırılıb (Qeyri-təhlükəsiz)
AES-128	128-bit	2^{128}	Müasir standart (Təhlükəsiz)
AES-256	256-bit	2^{256} klassik; Qrover: $\approx 2^{128}$	Kvant modelində azalmış, lakin böyük ehtiyat
RSA-2048	2048-bit	2^{112} (Simmetrik ekv.)	Asimmetrik standart

Tərif 5.1 (Diferensial kriptanaliz). *Şifrələmə alqoritminə daxil olan iki fərqli açıq mətnin bit fərqlərinin (giriş diferensialı) raundlar boyunca necə dəyişdiyini izləyərək, çıxışdakı şifrəli mətnlərin bit fərqi (çıkış diferensialı) olan təsirin ehtimal nəzəriyyəsi baxımından analizidir.*

5.1 Kritik Anlayış: Raund Açarının XOR ilə İxtisarı

Diferensial analizin təməl məntiqi XOR ($\oplus$) əməliyyatının xassəsinə əsaslanır. Tutaq ki, P və P' kimi iki fərqli mətn eyni gizli K_1 raund açarı ilə XOR-lanır. Hücümçü bu iki mətnin daxili fərqi (ΔX) baxdıqda:

$$\Delta X = (P \oplus K_1) \oplus (P' \oplus K_1) = P \oplus P' \oplus K_1 \oplus K_1 = P \oplus P' = \Delta P \quad (1)$$

Gizli K_1 açarı nə olursa olsun, iki mətnin fərqi hesablananda **açarlar bir-birini sıfırlayır**.

Riyazi Dəqiqləşdirmə: Eyni raund açarı hər AddRoundKey/XOR qatında iki icra arasında ləğv olunur: $(X \oplus K_r) \oplus (X' \oplus K_r) = X \oplus X'$. Qeyri-xətti S-qutusundan sonra isə verilmiş giriş fərqi tək bir çıxış fərqi deterministik müəyyən etmir; mümkün keçidlər DDT sayları və ehtimalları ilə izlənilir. Son raund sub-açarının namizədləri qismən tərs hesablama və statistik səsvermə ilə fərqləndirilir.

5.2 S-Qutusu Asimmetriyası və Diferensial Paylanma Cədvəli (DDT)

Blok şifrlərdə XOR ilə açar əlavə edilməsi və bit permutasiyası fərqi deterministik ötürür, xətti diffuziya qatı isə fərqi öz xətti xəritəsinə görə dəyişir. Qeyri-xətti **S-qutuları** üçün DDT lazımdır. Təsadüfi seçilmiş $n \rightarrow m$ funksiya üçün sabit sıfırdan fərqli giriş fərqi DDT xanasının *gözlənilən* sayı 2^{n-m} -dir; konkret cədvəl tam bərabər olmur. Üstəlik $S(x) \oplus S(x \oplus \Delta)$ eyni nizamsız cüt üçün iki dəfə sayıldığına görə sıfırdan fərqli Δ sətrində bütün DDT sayları cütdür.

Coxlu S-Qutusu Reallığı (DES Nümunəsi): DES kimi real blok şifrlərində paralel olaraq işləyən **8 fərqli S-qutusu** mövcuddur və hər biri $m = 4$ bit çıxış istehsal edir. Hücümçü laboratoriya analizində hər bir qutunun öz fərdi DDT cədvəlini ($2^6 \times 2^4$ ölçülü) hesablayır. Raundun global çıxış diferensialını tapmaq üçün isə aktiv olan (giriş fərqi sıfırdan fərqli olan) bütün S-qutularının fərdi keçid ehtimalları bir-birinə vurulur ($p_{raund} = p_{S_1} \cdot p_{S_2} \dots$). Bu səbəbdən, haker diferensial cıgırı qurarkən mümkün qədər az sayda S-qutusunu aktivləşdirən (yəni digər qutuların giriş fərqlərini $\Delta P = 0$ saxlayan) xüsusi giriş mətni cütləri seçməyə çalışır ki, ümumi vurma hasili kəskin şəkildə kiçilməsin.

Hücümçü hələ real şifrələmə maşınına müdaxilə etmədən, kağız üzərində sırf S-qutusunun strukturunu analiz edərək **diferensial paylanma cədvəlini** (DDT) qurur.

Nümunə 5.1 (Sadələşdirilmiş 2-bitlik S-qutusu üçün DDT analizi). *Tutaq ki, əlimizdə xətti olmayan $S(X)$ qutusu var. Hücümçü giriş fərqi $\Delta P = 01_2$ olaraq sabitləyir və bütün mümkün giriş cütlərini yoxlayır:*

- $P = 00_2, P' = 01_2 \implies \Delta P = 01_2$. *S-qutusu çıxışları:* $S(00) = 10_2, S(01) = 11_2 \implies \Delta C = 10 \oplus 11 = 01_2$
- $P = 10_2, P' = 11_2 \implies \Delta P = 01_2$. *S-qutusu çıxışları:* $S(10) = 00_2, S(11) = 01_2 \implies \Delta C = 00 \oplus 01 = 01_2$

Bu nümunədə dörd x dəyəri iki nizamsız giriş cütünü iki istiqamətdə sayır. Göstərilən iki cüt üçün eyni çıxış fərqi alınırsa, uyğun DDT xanasının sayı ən azı 4 və ehtimalı $4/4 = 1$ olar. Ümumiyyətlə, 2-bitlik sətirdə mümkün saylar 0, 2, 4-dür; 3/4 mümkün deyil. Daha böyük S-qutuda, məsələn, 6 uyğunluqdan 6/16 ehtimal yarana bilər.

5.3 Riyazi İş Prinsipi və Mərhələləri

Diferensial hücum iki ardıcıl fazada icra edilir:

1. **Mərhələ 1: Laboratoriya Analizi (Açırsız Diferensial Cığır):** Hücumçu DDT cədvəlindəki ən yüksək ehtimallı fərq keçidlərini zəncirvari şəkildə birləşdirərək raundlararası global bir **diferensial cığır** qurur. Məsələn, 3 raundlu bir şifrə üçün cığır belə görünə bilər:

$$\Delta P \xrightarrow{p_1} \Delta A \xrightarrow{p_2} \Delta B \xrightarrow{p_3} \Delta C_{son}$$

Bu cığırın ümumi başvermə ehtimalı raundların müstəqilliyi fərziyyəsi altında $p_{global} = p_1 \cdot p_2 \cdot p_3$ kimi hesablanır.

2. **Mərhələ 2: Real Hücum və Statistik Səsvərmə (Açarın Bərpası):** Haker aralarındakı fərq dəqiq ΔP olan N sayda xüsusi mətn cütü ($P_i \oplus P'_i = \Delta P$) hazırlayır. Burada tələb olunan mətnlərin sayı ümumi ehtimalla tərs mütənasibdir ($N \approx c/p_{global}$).

Bu cütləri hədəf sistemə göndərərək çıxan şifrləli mətn cütlərini (C_i, C'_i) toplayır. Sonuncu raundun S-qutusuna təsir edən bütün mümkün sub-açar (K_{son}) namizədlərini tək-tək simulyasiya edərək S-qutusundan geriyə doğru fərq hesablayır:

- **Səhv açar namizədləri:** Seçilmiş diferensial üçün daha çox fon/küy səviyyəsində uyğunluq verir; paylanma avtomatik ideal təsadüfi və ya sıfır deyil.
- **Doğru açar namizədi:** Kifayət qədər məlumat və yaxşı seçilmiş cığır olduqda statistik sayğacda gözlənilən meyli daha güclü göstərə bilər. Nəticə ayrıca tam açar yoxlaması ilə təsdiqlənir.

Nümunə 5.2 (DES S-qutularının diferensial dayanıqlığı). *DES-in 16 raundlu tam strukturu diferensial kriptanalizə qarşı gözləniləndən daha dayanıqlıdır. Biham və Şamir araşdırmaları zamanı aşkar etdilər ki, DES-in dizaynerləri (IBM və NSA) hələ 1970-ci illərdə bu hücum növündən gizlicə xəbərdar olmuş və S-qutularını diferensial xarakteristikaların ehtimalını minimuma endirəcək şəkildə xüsusi optimallaşdırmışlar. Tam 16 raundlu DES-i diferensial analizlə sındırmaq üçün 2^{47} seçilmiş açıq mətn tələb olunur ki, bu da tam axtarış hücumundan (2^{55} orta halda) daha effektiv olsa da, hələ də praktiki cəhətdən çox ağırdır.*

6 Xətti Kriptanaliz

Xətti kriptanaliz — **Mitsuru Matsui** tərəfindən 1993-cü ildə təqdim edilən, **məlum açıq mətn** modelinə əsaslanan və blok şifrlərin daxili S-qutularının xətti funksiyalara yaxınlıq dərəcəsindən istifadə edən struktur hücum üsuludur (Matsui, 1994a).

Tərif 6.1 (Xətti kriptanaliz). *Açıq mətn, şifrəli mətn və daxili raund açarlarının müəyyən bitlərinin xətti kombinasiyasını (XOR cəmini) yüksək ehtimallı statistik asılılıq tənliyi şəklində ifadə edən analiz üsuludur.*

Kritik Anlayış: Bu hücum modelində şifrələmə üçün istifadə olunan gizli K açarı **sabitdir və yeganədir**. Hücumçu eyni gizli açarla şifrələnmiş çoxlu sayda (N sayda) fərqli P və C cütlərinə malikdir. Tənliklərdə görünən indekslər paketlərin sayını deyil, **bir paketin daxilindəki konkret bit mövqelərini** (məsələn, 3-cü, 5-ci bit) göstərir.

6.1 Riyazi İş Prinsipi və Mərhələləri

1. **Xətti yaxınlaşma tənliyinin qurulması:** S-qutularındakı qeyri-xəttiliyi yan keçmək üçün açıq mətnin, şifrəli mətnin və gizli açarın müəyyən sabit bitləri arasında xətti bir cığır formalaşdırılır:

$$P[i] \oplus P[j] \oplus C[m] = K[k] \quad (2)$$

Burada sol tərəf hakerə məlumdur və hər şəbəkə paketi üçün dinamik olaraq dəyişir. Sağ tərəf ($K[k]$) isə naməlumdur, lakin bütün paketlər boyunca sabitdir (0 və ya 1).

Kombinatorik Qeyd: Niyə Hücum Kor-koranə Axtarıla İcra Olunmur?

Kombinatorika nöqteyi-nəzərindən k -bitlik bir blokda bu formada qurula biləcək bütün mümkün tənliklərin ümumi sayı təxminən $\binom{k}{2} \cdot k \cdot k \approx \mathcal{O}(k^4)$ dərəcəsinə çatır. Lakin blok şifrlərdə tətbiq olunan **uğun effekti** və güclü **diffuziya** mexanizmləri səbəbindən, raundların sayı artdıqca bu sadə tənliklərin meyllilik dərəcəsi sürətlə sıfıra ($\epsilon \rightarrow 0$) enir. Bu səbəbdən analitiklər $\mathcal{O}(k^4)$ mürəkkəbliyə qlobal axtarış aparmaq yerinə, hər bir raundun daxili S-qutularını lokal olaraq tədqiq edirlər.

2. **Xətti Meyllilik Dərəcəsinin Rolu:** Qurulmuş bu xətti tənliyin doğru olma ehtimalı p ilə işarə edilir. İdeal bir şifrdə bu ehtimal dəqiq $p = 1/2$ (50%) olmalıdır. Xətti kriptanalizdə isə bu ehtimalın yarıdan fərqlənmə dərəcəsi, yəni **meyllilik dərəcəsi** (ϵ) axtarılır:

$$\epsilon = p - \frac{1}{2} \quad (3)$$

Hücumun reallaşması üçün mütləq $\epsilon \neq 0$ olmalıdır. Meylliliyin olması şifrələmə alqoritminin daxilə tam təsadüfi işləmədiyini və kənara statistik sızıntı verdiyini göstərir.

3. **Məlumat mürəkkəbliyinin müəyyən edilməsi:** Statistikada Matsui teoremi ilə sübut olunur ki, təsadüfi küyü üstələmək və bu asılılığı aşkar etmək üçün tələb olunan fərqli məlum mətn cütlərinin ümumi sayı (N) meylliliyin kvadratı ilə tərs mütənəsbdir:

$$N \propto \frac{1}{\epsilon^2} \quad (4)$$

4. **Açar bitlərinin statistik səsvermə ilə bərpası:** Hücum edən şəxs əlindəki N sayda fərqli P və C cütlərini tənliyin sol tərəfində yerinə qoyaraq nəticələrin tezliyini hesablayır. Əgər paketlərin böyük əksəriyyətində sol tərəfin cavabı 1 alınarsa, sistem sabit $K[k]$ açar bitinin 1 olduğuna doğru meyllənir; əks halda bit 0 qəbul edilir.

Nümunə 6.1 (DES alqoritminin xətti kriptanaliz ilə sındırılması). *Mitsuru Matsui 1994-cü ildə bu metodun gücünü nümayiş etdirmək üçün eyni açarla şifrələnmiş 2^{43} (təxminən 8.8 trilyon) məlum fərqli açıq mətn-şifrəli mətn cütünü statistik analizdən keçirərək, 16 raundlu standart DES alqoritminin gizli açarını ilk dəfə praktik olaraq bərpa etməyi bacarmışdır (Matsui, 1994b).*

6.2 Meyllilik Dərəcəsinin Analitik Tapılması Metodologiyası

Hücum edən şəxs xətti tənliyin doğru olma ehtimalını (p) və meyllilik dərəcəsinə (ϵ) hələ hücumla başlamadan öncə, tamamilə açıq şəkildə, şifrənin hamısına məlum olan açıq riyazi strukturu (S-qutusu cədvəlləri) üzərindən iki mərhələdə hesablayır:

1. **Lokal Səviyyədə — Xətti Yaxınlaşma Cədvəlinin (LAT) Qurulması:** Analitik, S-qutusunun bütün mümkün giriş bit kombinasiyalarını və onlara qarşılıq çıxan çıxış bitlərini kompüter mühitində simulyasiya edir. Giriş və çıxış bitlərinin xətti kombinasiyalarının neçə vəziyyətdə ödənilməsi sayılır və hər bir S-qutusu komponenti üçün lokal meyllilik dərəcəsi ($\epsilon_{sbox} = p_{sbox} - 1/2$) hesablanaraq cədvələ yazılır.
2. **Qlobal Səviyyədə — Matsuinin Yığılma Lemmasının Tətbiqi:** Raundlar boyunca uzanan çoxlu sayda lokal xətti tənliklər bir-birinə zəncirvari şəkildə bağlanaraq qlobal bir "xətti çıxır" formalaşdırır. Müstəqil raundların lokal meylliliklərini birləşdirərək alqoritmin ümumi qlobal meylliliyini (ϵ_{total}) hesablamaq üçün Matsuinin yığılma lemmasından istifadə olunur. n sayda müstəqil xətti yaxınlaşma üçün qlobal meyllilik aşağıdakı düsturla müəyyən edilir:

$$\epsilon_{total} = 2^{n-1} \prod_{i=1}^n \epsilon_i \quad (5)$$

Matsuinin Yığılma Lemmasının Riyazi İzbatı

Lemmanın mahiyyətini anlamaq üçün daxili strukturu tam müstəqil olan iki təsadüfi ikili (0 və ya 1) dəyişənə baxaq: X_1 və X_2 . Bu dəyişənlərin 0-a bərabər olma ehtimalları müvafiq olaraq p_1 və p_2 olsun:

$$P(X_1 = 0) = p_1 = \frac{1}{2} + \epsilon_1 \quad \text{və} \quad P(X_2 = 0) = p_2 = \frac{1}{2} + \epsilon_2 \quad (6)$$

Burada ϵ_1 və ϵ_2 uyğun olaraq dəyişənlərin lokal meyllilik dərəcələridir. Onda bu dəyişənlərin 1 olma ehtimalları avtomatik olaraq aşağıdakı kimi olar:

$$P(X_1 = 1) = 1 - p_1 = \frac{1}{2} - \epsilon_1 \quad \text{və} \quad P(X_2 = 1) = 1 - p_2 = \frac{1}{2} - \epsilon_2 \quad (7)$$

Xətti kriptanalizdə biz raundları XOR əməliyyatı ilə birləşdiririk. Gəlin bu iki müstəqil raundun cəminin ($X_1 \oplus X_2 = 0$) doğru olma ehtimalını ($p_{1,2}$) hesablayaq. İki bitin XOR cəminin 0 verməsi üçün gərək hər iki bit bir-birinə bərabər olsun (yəni ya hər ikisi 0, ya da hər ikisi 1 olmalıdır):

$$p_{1,2} = P(X_1 \oplus X_2 = 0) = P(X_1 = 0, X_2 = 0) + P(X_1 = 1, X_2 = 1) \quad (8)$$

Dəyişənlər müstəqil olduğu üçün birgə ehtimalı onların hasili şəklində yazı bilərik:

$$p_{1,2} = p_1 p_2 + (1 - p_1)(1 - p_2) \quad (9)$$

$$= \left(\frac{1}{2} + \epsilon_1\right) \left(\frac{1}{2} + \epsilon_2\right) + \left(\frac{1}{2} - \epsilon_1\right) \left(\frac{1}{2} - \epsilon_2\right) \quad (10)$$

$$= \left(\frac{1}{4} + \frac{\epsilon_1}{2} + \frac{\epsilon_2}{2} + \epsilon_1 \epsilon_2\right) + \left(\frac{1}{4} - \frac{\epsilon_1}{2} - \frac{\epsilon_2}{2} + \epsilon_1 \epsilon_2\right) \quad (11)$$

Tənlikdəki $\frac{\epsilon_1}{2}$ və $\frac{\epsilon_2}{2}$ ifadələri əks işarəli olduqları üçün bir-birini islah edir. Yerdə qalan hədləri topladıqda alırıq:

$$p_{1,2} = \frac{1}{4} + \frac{1}{4} + 2\epsilon_1\epsilon_2 = \frac{1}{2} + 2\epsilon_1\epsilon_2 \quad (12)$$

Tərifə görə, iki raund üçün birləşmiş meyllilik dərəcəsi $\epsilon_{1,2} = p_{1,2} - 1/2$ bərabərdir. Yuxarıdakı nəticədən $1/2$ -ni çıxdıqda tapırıq:

$$\epsilon_{1,2} = 2\epsilon_1\epsilon_2 \quad (13)$$

Riyazi induksiya metodunu tətbiq edərək bu məntiqi n sayda müstəqil raund dəyişəni üçün genişləndirdikdə, hər növbəti raundda hasilin qarşısına əlavə bir 2 əmsalı gəlir və ümumi düstur öz isbatını tapır:

$$\epsilon_{total} = 2^{n-1} \prod_{i=1}^n \epsilon_i \quad (14)$$

Bu isbat aydın şəkildə nümayiş etdirir ki, raundların sayı (n) artdıqca meyllilik dərəcələri bir-birinə vurulur və kəsr ədədlər sürətlə kiçildiyi üçün qlobal meyllilik sıfıra doğru yaxınlaşır ($\epsilon_{total} \rightarrow 0$). Bu səbəbdən raund sayını artırmaq blok şifr alqoritmlərini xətti kriptanalizə qarşı eksponensial dərəcədə dayanıqlı edir.

Beləliklə, analitik şifrın riyazi modelindən çıxış edərək qlobal ϵ dəyərini tam dəqiq hesablayırıq. Bu rəqəm hücum edən şəxsə tələb olunan minimal fərqli məlum mətn sayını ($N \propto \epsilon^{-2}$) hücumdan əvvəl proqnozlaşdırmağa imkan verir.

6.3 Diferensial və Xətti Kriptanalizin Müqayisəli Təhlili

Hər iki kriptanaliz növü blok şifrlərin struktur asılılıqlarını hədəf alsada, tələb etdikləri məlumat modelləri və riyazi yanaşmaları baxımından fərqlənirlər.

Cədvəl 2: Diferensial və xətti kriptanalizin müqayisəli xüsusiyyətləri

Xüsusiyyət	Diferensial Kriptanaliz	Xətti Kriptanaliz
Riyazi Əsas	XOR fərqlərinin yayılması (Δ)	Xətti yaxınlaşma və meyllilik (ϵ)
Məlumat modeli	Seçilmiş açıq mətn	Məlum açıq mətn
Məlumat Mürəkkəbliyi (DES)	2^{47} seçilmiş mətn cütü	2^{43} məlum mətn cütü
Hesablama (Zaman) Mürəkkəbliyi	2^{47} əməliyyat (Nəzəri olaraq tam axtarışdan sürətli)	2^{43} əməliyyat (Praktiki olaraq icra edilib)
Hədəf Komponent	S-qutularının diferensial keçidləri	S-qutularının xətti yaxınlaşması
Təqdimatçı və İl	E. Biham, A. Şamir (1990)	M. Matsui (1993 – Nəzəriyyə, 1994 – Praktika)

Aralıq özünüoxlama

Bu nöqtədə tələbə tam axtarışın, diferensial və xətti kriptanalizin primitivin riyazi strukturuna və açar fəzasına yönəldiyini izah etməlidir. Növbəti hissədə isə primitiv deyil, onun real icrası və ölçülə bilən sızıntılar hədəf alınır.

II hissə: Implementasiya və fiziki sızıntılar

7 Yan Kanal Hücumlarına Giriş

Tərif 7.1 (Yan kanal hücumu). *Yan kanal hücumu (SCA) — kriptografik alqoritmin riyazi quruluşundakı zəiflikdən deyil, onun real mikrosxem, prosessor və ya aparat təminatı üzərindəki fiziki reallaşdırılmasından ətraf mühitə sızan məlumatdan istifadə edən hücum üsuludur (Kocher, 1996).*

Fiziki və Məntiqi Yan Kanal Mənbələri: Hücumçunun hədəf aldığı sızıntı xarakterindən asılı olaraq yan kanallar aşağıdakı qruplara ayrılır:

- **İcra müddəti:** Müəyyən daxili riyazi əməliyyatların (məsələn, modul dərəcəyə yüksəltmə və ya şərti budaqlar) icra müddətinin gizli açarın bitlərindən asılı olaraq dəyişməsi.
- **Enerji sərfiyyatı:** Tranzistorların keçidi zamanı mikrosxemin daxili şinlərindən çəkdiyi elektrik cərəyanının dinamik dəyişməsi (SPA və DPA hücumları) (Kocher et al., 1999).
- **Elektromaqnit şüalanması (EM):** Prosessorun daxili elementlərindən yüksək tezliklərdə işləyən cərəyan keçərkən mikrosxem ətrafında yaranan parazit EM sahələr.
- **Akustik sızıntı:** Cihazın gərginlik tənzimləyiciləri və kondensatorlarından əməliyyat zamanı yaranan yüksək tezlikli ultrasəs dalğaları.
- **İstilik:** Uzunmüddətli ağır şifrələmə əməliyyatları zamanı çipin müəyyən zonalarının lokal qızma dərəcəsi.
- **Keş yaddaş kanalları (Keş-vaxt):** Proqram təminatının prosessorun keş yaddaşına ($L1/L2$ Keş) müraciət fərqləri (məsələn, AES-in T -cədvəllərinin keş daxilində törətdiyi sızıntılar).
- **Xəta mesajları və doldurma xətası üzrə sorğu mənbələri:** Protokol səviyyəsində şifrəli mətnin struktur xətələrinin kənara fərqli kodlarla qaytarılması.

Əsas fərq: Ənənəvi kriptozanaliz (məsələn, diferensial və xətti analizlər) alqoritmi daxili dəyişənləri və açarı tapılmalı olan riyazi qara qutu kimi qəbul edir. Yan kanal hücumları isə alqoritmin icra olunduğu fiziki mühiti müşahidə edilə bilən boz qutu modelinə çevirir.



Şəkil 1: Klassik şifrələmə zəncirində fiziki yan kanalların formalaşması

8 Vaxt Hücumu (Vaxt Hücumu)

8.1 İş Prinsipi

Vaxt hücumu — **Paul Kocher** tərəfindən 1996-cı ildə kəşf edilmiş fundamental yan kanal hücumudur (Kocher, 1996). Bu hücum metodu, kriptografik alqoritmin icra olunduğu prosessorada əməliyyatların tamamlanma müddətində yaranan mikrosaniyəlik və ya nanosaniyəlik fərqləri hədəf alır.

Tərif 8.1 (Vaxt hücumu). *Kriptografik cihazın daxili hesablama müddətinin gizli açarın bit dəyərlərindən və ya daxil edilən verilənlərdən funksional olaraq asılı olmasından istifadə edərək, statistik analiz vasitəsilə gizli açarı addım-addım bərpa edən hücum metodudur.*

Fundamental Analitik Prinsip:

- **Dinamik zamanlama:** Prosessorun daxilində icra olunan şərti budaqlar və ya asimmetrik riyazi əməliyyatlar fərqli giriş verilənləri üçün müxtəlif takt sayları tələb edir.
- **Statistik Süzgəc:** Hücumçu hədəf sistemə çoxlu sayda fərqli giriş göndərir və hər birinin icra müddətini dəqiq qeyd edir. İcra müddətindəki küyü aradan qaldırmaq üçün böyük verilənlər üzərində statistik korrelyasiya təhlilləri aparılır.
- **Addımlı Təxmin:** Gizli açarın bitləri soldan sağa doğru bir-bir test edilir. Hər bir bit təxmini üçün hesablanan nəzəri zamanlama modeli real ölçülmüş zamanla müqayisə edilərək doğru bit müəyyənləşdirilir.

8.2 RSA Alqoritminə qarşı Vaxt Hücumu

RSA asimmetrik şifrələməsində və rəqəmsal imzada istifadə olunan $M^d \pmod{n}$ modul dərəcəyə yüksəltmə əməliyyatı hesablama resurslarına qənaət etmək üçün **kvadrat yüksəlt və vur** alqoritmi ilə icra edilir.

Alqoritm: Kvadrat Yüksəlt və Vur metodu

Giriş: Giriş əsası g , gizli dərəcə $x = (x_k x_{k-1} \dots x_0)_2$, modul p

Çıxış: Nəticə $R = g^x \pmod{p}$

1. $R \leftarrow 1$ edilir.
2. $i = k$ -dan 0-a qədər hər bir bit üçün ardıcıl dövr icra olunur:
 - a) $R \leftarrow (R \times R) \pmod{p}$ (Kvadrat Yüksəltmə — hər bir bit üçün)
 - b) **Əgər** gizli açarın cari bit $x_i == 1$ olarsa:

$$R \leftarrow (R \times g) \pmod{p}$$
 (**Kritik Asimmetriya:** Yalnız bit 1 olduqda)
3. R dəyəri geri qaytarılır.

Cədvəl 3: Kvadrat Yüksəlt və Vur Alqoritminin Riyazi Strukturu

Asimmetriya Problemi və Sızıntı Mexanizmi: Yuxarıdakı alqoritmədən göründüyü kimi, gizli açarın (x) cari bit 0 olduqda dövr daxilində yalnız 1 böyük modul əməliyyatı (Kvadrat

yüksəltmə) icra olunur. Lakin bit 1 olduqda ardıcıl olaraq 2 böyük modul əməliyyatı (Kvadrat yüksəltmə və Vurma) icra edilir. İki modul əməliyyatının icrası zaman baxımından bir əməliyyatdan nəzərəcarpacaq dərəcədə çox çəkir. Bu zaman fərqi birbaşa olaraq gizli açarın daxili bitləri haqqında kənara ifşəedici signal ötürür.

8.3 Nəzəri Müdafiə Strategiyaları

1. **Sabit-Zamanlı İkili Alqoritmlər (*Constant-Time Binary Algorithms*):** Montqomeri nərdivanı (*Montgomery ladder*) və ya "həmişə vur" (*always-multiply*) yanaşması emal edilən hər bir bit üçün eyni formal əməliyyat ardıcılığını icra edir. Ara nəticələrin gizli bitin qiymətindən asılı olaraq seçilməsi şərti budaqlanmasız (*branchless*) sabit-zamanlı mübadilə/seçmə (*constant-time swap/select*) əməliyyatları ilə aparılmalıdır. Həmçinin kompilyatorun optimallaşdırma çıxışı və böyük-ədəd arifmetikası (*bignum arithmetic*) kitabxanalarının dəyişən müddətli icra xarakteristikası yoxlanılmalıdır.
2. **Kriptografik Korlaşdırma (*Cryptographic Blinding*):** RSA alqoritmində vaxt (*timing attack*) və enerji sızmalarına (*DPA*) qarşı effektiv müdafiə qatıdır. Cihaz gizli eksponentlə hesablama aparmazdan əvvəl daxil olan mesajı təsadüfi və modula görə tərs elementə malik maskalama faktoru ilə korlaşdırır:

$$M' = (M \cdot r^e) \bmod n \quad (15)$$

Daha sonra M' üzərində gizli dərəcəyə yüksəltmə əməliyyatı $C' = (M')^d \bmod n$ icra olunur və nəticə $r^{-1} \bmod n$ vurğunu ilə bərpa edilir (*unblinding*):

$$M = (C' \cdot r^{-1}) \bmod n \quad (16)$$

Kriptografik baxımdan təhlükəsiz təsadüfi ədəd generatoru (TRNG/CSPRNG) və düzgün reallaşdırma statistik korrelyasiyanı kəskin azaldır. Lakin qalıq fiziki sızma, RNG çatışmazlığı və xəta inyeksiyası (*fault injection*) hücumlarına qarşı əlavə nəzarət mexanizmləri tətbiq olunmalıdır.

9 Enerji Analizi (Enerji Analizi)

9.1 SPA (Simple Enerji Analizi — Sadə Enerji Analizi)

Tərif 9.1 (SPA). SPA — kriptografik cihazın tək bir şifrələmə əməliyyatı zamanı istehlak etdiyi cərəyanın **zaman qrafikindən (enerji izindən)** birbaşa vizual analiz vasitəsilə gizli açarı və ya icra olunan əməliyyatların ardıcılığını oxumağa imkan verən hücum metodudur (*Kocher et al., 1999*).

Fundamental İş Prinsipi:

- **Əməliyyat Asılılığı:** CMOS mikrosxemlərində fərqli riyazi əməliyyatlar (məsələn, böyük ədədlərin vurulması ilə toplanması) fərqli sayda tranzistor keçidi tələb edir və bu da enerji əyrisində xarakterik dalğalar yaradır.
- **Görünüşə görə tanıma:** Kvadrat yüksəlt və vur alqoritmində kvadrat yüksəltmə və vurma əməliyyatlarının enerji profilləri fərqlidir. Hücumçu osilloqraf ekranındakı dalğalara baxaraq gizli açarın 0 (tək dalğa) və ya 1 (qoşa dalğa) olduğunu birbaşa müəyyən edir.

SPA Sızıntı Profili (Kvadrat Yüksəlt və Vur)			
Enerji İstehlakı (ΔI)			
↑	Kvadrat Yüksəltmə (Geniş dalğa)	Kvadrat Yüksəltmə (Geniş dalğa)	Əlavə Vurma (Dar dalğa)
Zaman (t) →	[Təxmin edilən gizli bit ardıcılığı: 0 → 1]		

Cədvəl 4: Sadə Enerji Analizində əməliyyatların vizual ayrılması

9.2 DPA (Differential Enerji Analizi — Diferensial Enerji Analizi)

Tərif 9.2 (DPA). *DPA — çoxsaylı kriptografik əməliyyatdan toplanan enerji izlərini statistik və ehtimal metodları ilə analiz edib sızıntı hipotezlərini açar namizədləri üzrə yoxlayan hücum üsuludur; tələb olunan iz sayı sabit deyil (Kocher et al., 1999).*

Alqoritmik İcra Addımları:

- Verilənlərin Toplanması:** Cihaza N sayda fərqli təsadüfi P_i açıq mətnləri göndərilir və hər bir icra üçün cərəyan dəyişməsi ($T_i(t)$ izləri) yaddaşa yazılır.
- Açar Təxmini və Proqnoz:** Hücumçu gizli açarın kiçik bir hissəsi (məsələn, AES-in ilk baytı) üçün mümkün olan bütün qiymətləri təxmin edir.
- Aralıq dəyişənin hesablanması:** Hər bir təxmin üçün şifrələmənin daxili bir aralıq nöqtəsindəki (məsələn, S-qutusunun çıxışı) dəyər hesablanır.
- Qruplaşdırma (Diferensiallama):** Hesablanan dəyərin müəyyən bir bitinin 0 və ya 1 olmasına əsasən, toplanmış bütün $T_i(t)$ izləri iki fərqli qrupa ayrılır.
- Statistik Fərq:** Bu iki qrupun orta hesabi qiymətlərinin fərqi (ΔD) hesablanır. Əgər açar təxmini səhvdirsə, qrafik sıfıra yaxın düz xətt olacaq. Əgər təxmin doğrudursa, real cərəyan istehlakı ilə korrelyasiya yarandığı üçün fərq qrafikində kəskin korrelyasiya pikləri (sıçrayışlar) görünəcək.

9.3 Nəzəri Müdafiə Strategiyaları

- Kriptografik Maskalama :** Daxili həssas dəyişənlərin (məsələn, x) enerji sızıntısını kəsmək üçün onlar cihaz daxilində tam təsadüfi r maskası ilə modifikasiya edilir:

$$x_{\text{masked}} = x \oplus r$$

Bütün aralıq əməliyyatlar bu maskalanmış dəyər üzərində aparılır. Yalnız ən sonda maska riyazi olaraq çıxarılır. Hücumçu cərəyanı ölçsə belə, hər şifrələmədə r dəyişdiyi üçün enerji istehlakı gizli açarla heç bir statistik əlaqəyə malik olmur.

- Prototip Səviyyəsində Körləşdirmə :** RSA kimi asimmetrik alqoritmlərdə açarın riyazi olaraq maskalanmasıdır:

$$d_{\text{blinded}} = d + k \cdot \varphi(n) \quad (\text{burada } k \text{ təsadüfi ədəddir})$$

Euler teoreminə uyğun olaraq nəticə qorunur; eksponentin hər icrada dəyişməsi sadə iz korrelyasiyasını azalda bilər, lakin bütün sızıntını aradan qaldırdığı fərz edilməməlidir.

3. Aparat Təminatı Səviyyəsində Müdafiə :

- **Səs-küy inyeksiyası:** Çip daxilinə parazit cərəyan çəkən generatorların yerləşdirilməsi.
- **Ardıcılığın qarışdırılması:** Müstəqil daxili əməliyyatların (məsələn, AES S-qutularının) icra ardıcılığının hər dəfə təsadüfi olaraq dəyişdirilməsi.

10 Elektromaqnit Hücumları (EMA)

Tərif 10.1 (EMA). *EMA — kriptografik qurğunun daxili keçid şinlərindən və tranzistorlarından yüksək tezliklərdə keçən cərəyanın mikrosxem ətrafında yaratdığı parazit elektromaqnit sahələrini (şüalanmanı) xüsusi antenalar və zondlar vasitəsilə qeydə alaraq gizli məlumatları əldə edən yan kanal hücumudur (Mangard et al., 2007).*

Fundamental Xüsusiyyətləri:

- **Təmassız və uzaqdan təhlil:** Enerji analizindən fərqli olaraq, cihazın elektrik xəttinə fiziki müdaxilə (məsələn, müqavimət lehimləmək) tələb olunmur. Hücum bir neçə millimetrdən (yerli EMA) bir neçə metrə qədər məsafədən icra edilə bilər.
- **Məkan seçiciliyi:** EM zondları mikrosxemin konkret zonasına yönəldilərək başqa bloklardan gələn küyü azalda və yerli sızıntını gücləndirə bilər; küy tam sıfırlanmır.
- **TEMPEST Standartları:** Hərbi və dövlət əhəmiyyətli informasiya sistemlərinin bu növ EM sızıntılarına qarşı müdafiə səviyyəsini tənzimləyən beynəlxalq təhlükəsizlik standartları toplusudur. Cihazların Faraday qəfəsi və ya xüsusi ekranlaşdırıcı materiallarla izolyasiyasını tələb edir.

11 Keş Yaddaş Hücumları (Keş Hücumları)

Tərif 11.1 (Keş hücumu). *Keş hücumu — müasir prosessorların daxili keş yaddaş iyerarxiyasındakı (L1, L2, LLC) verilənlərə müraciət sürətlərinin fərqliliyinə (keşə düşmə və keşdən yayınma zaman fərqləri) əsaslanaraq, eyni prosessorda işləyən digər qurban proqramın gizli məlumatlarını və kriptografik açarlarını əldə edən mikroarxitektura yan kanal hücumudur (Bernstein, 2005).*

Fundamental Mexanizm və Əsas Növləri: Hücumçu birbaşa olaraq qurbanın yaddaşını oxuya bilmir, lakin prosessorun keş sətrlərini ortaq resurs kimi manipulyasiya edir:

1. Prime+Probe (Doldur və Yoxla):

- **Prime:** Hücumçu keş yaddaşın hədəf setini tamamilə özünün mənasız verilənləri ilə doldurur.
- **Gözləmə:** Qurban proqramın (məsələn, AES şifrələməsinin) icrasına icazə verilir. Əgər qurban hücumçunun doldurduğu çoxluğa aid olan bir ünvanı müraciət edərsə, hücumçunun verilənlərini keşdən sıxışdırıb çıxarır.
- **Yoxlama:** Hücumçu öz verilənlərinə yenidən müraciət edir və keçən zamanı ölçür. Əgər müraciət müddəti uzundursa (*keşdən yayınma*), deməli qurban proqram həmin konkret keş sətrindən istifadə edib.

2. Flush+Yenidən yükləmə (Təmizlə və Yenidən Yüklə):

- **Ön şərt:** Hücumçu ilə qurban arasında paylaşılmış kitabxanaların (məsələn, *crypto.dll* və ya *libcrypto.so*) mövcudluğunu tələb edir.
- **Flush:** Hücumçu xüsusi prosessor əmri ilə (məsələn, *clflush*) hədəf aldığı yaddaş ünvanını keş yaddaşdan tamamilə silir.
- **Gözləmə:** Qurban proqramın icrası gözlənilir.
- **Yenidən yükləmə:** Hücumçu həmin ünvana yenidən müraciət edir. Əgər müraciət inanılmaz dərəcədə sürətlidirsə (*keşə düşmə*), deməli qurban bu zaman kəsiyində həmin funksiyaya və ya cədvələ müraciət edərək onu yenidən keşə gətirib.

Nümunə 11.1 (AES T-Cədvəllərinə qarşı keş hücumu). *Proqram təminatı səviyyəsində icra olunan sürətli AES reallaşdırmaları daxili SubBytes, ShiftRows və MixColumns mərhələlərini birləşdirərək onları əvvəlcədən hesablanmış T-cədvəlləri şəklində saxlayır. Hücumçu yuxarıdakı metodlarla cədvəlin hansı indekslərinə (məsələn, $T_0[i]$) müraciət edildiyini keş vaxtından tutmaqla, $i = P \oplus K$ əlaqəsindən gizli açarı (K) riyazi olaraq hesablayır.*

12 Xəta İnyeksiyası Hücumları (Xəta İnyeksiyası Hücumları)

Tərif 12.1 (Xəta inyeksiyası hücumu). *Xəta inyeksiyası hücumu — kriptografik əməliyyatın icrası zamanı xarici fiziki təsirlər (məsələn, gərginlik sıçrayışları, saat tezliyinin manipulyasiyası, lazer impulsları və ya temperatur) vasitəsilə cihazın aparat təminatında qəsdən hesablama xətası tətbiq edərək səhv nəticələr əldə etmə və bu xətalərin təbiətini analiz edərək gizli açarı çıxarma üsuludur (Boneh et al., 1997).*

12.1 DFA: diferensial xəta analizi

Tərif 12.2 (DFA). *DFA — eyni giriş verilənləri üçün cihazdan alınan düzgün şifrəli mətn (C) ilə xəta vurulmuş səhv şifrəli mətnin ($\hat{C}$) bit səviyyəsində fərqlərini müqayisə edərək, kriptografik alqoritmin daxili diffuziya mexanizmini geriye doğru izləyən və açarı tapan kriptanalitik üsuldur (Biham and Shamir, 1997).*

12.2 RSA-CRT Alqoritminə qarşı Bellcore Xəta İnyeksiyası Hücumu

RSA imzalama əməliyyatını sürətləndirmək üçün Çin qalıqlar teoremindən (CRT) istifadə edilir. Sistem $n = p \cdot q$ modulu üzərində birbaşa hesablama aparmaq əvəzinə, əməliyyatı daha kiçik olan p və q modulları üzrə iki müstəqil qola ayırır:

$$\begin{aligned} d_p &= d \bmod (p-1), & s_1 &= m^{d_p} \bmod p, \\ d_q &= d \bmod (q-1), & s_2 &= m^{d_q} \bmod q. \end{aligned}$$

Sonda bu iki aralıq dəyər CRT riyazi strukturu ilə birləşdirilərək yekun s imzası alınır.

Sızıntı və Hücum Mexanizmi: Hücumçu cihaz s_1 dəyərini hesablayan zaman gərginliyi anlıq dəyişərək xəta törədir və nəticədə səhv $\hat{s}_1$ dəyəri alınır. Lakin s_2 hesablama qolu tamamilə düzgün icra olunur. Bu halda birləşdirilmiş yekun imza səhv ($\hat{s}$) olur.

Bu zaman riyazi olaraq aşağıdakı şərtlər yaranır:

$$\begin{aligned}\hat{s} &\not\equiv s_1 \pmod{p} \implies (\hat{s}^e - m) \not\equiv 0 \pmod{p} \\ \hat{s} &\equiv s_2 \pmod{q} \implies (\hat{s}^e - m) \equiv 0 \pmod{q}\end{aligned}$$

Bu o deməkdir ki, $(\hat{s}^e - m)$ ədədi q -yə tam bölünür, lakin p -yə bölünmür. Hücümçü açıq eksponenti (e), kodlaşdırılmış mesaj nümayəndəsini (m) və səhv imzanı ($\hat{s}$) istifadə edərək ən böyük ortaq bölən (ƏBOB) vasitəsilə gizli q vuruğunu hesablaya bilər:

$$\gcd(\hat{s}^e - m, n) = q$$

Bu GCD hesablaması böyük ədədlər üçün praktik olaraq ucuzdur; əsas çətinlik uyğun xəta inyeksiyası modelində səhv imzanı əldə etməkdir.

12.3 Nəzəri Müdafiə Strategiyaları

- **Çıxışın Yoxlanması (Çıxışın Yoxlanması):** Cihaz yekun nəticəni kənara ötürməzdən əvvəl imzanı açıq açarlarla yoxlayır; bəsit nümayəndəsi üçün $s^e \bmod n = m$, real sxemdə isə RSA-PSS/PKCS#1 kodlaşdırmasının tam yoxlama proseduru tətbiq olunur. Yoxlama uğursuz olarsa səhv imza çıxışa verilməməlidir. Alternativ sübut edilmiş xəyata davamlı CRT sxemi seçilə bilər.
- **İnvariantların və Paritetin Yoxlanması:** Hesablama registrlərinə paritet bitləri əlavə edilir. Əgər fiziki müdaxilə zamanı hər hansı bir bit çevrilərsə, paritet xətası aparat səviyyəsində əməliyyatı dayandırır.
- **Korlaşdırmanın Məhdudiyyəti:** Mesaj və eksponent korlaşdırması bəzi vaxt/enerji sınıtlarını azaltmağa kömək edir, lakin Bellcore xəta inyeksiyası hücumuna əsas müdafiə deyil. Xəta korlaşdırma açıldıqdan sonra səhv imza kimi çıxış bilər və məlum mesajla GCD əlaqəsi yenə qurular. Buna görə korlaşdırma çıxış yoxlamasını əvəz etməməlidir.

13 Digər Yan Kanal Hücumları

13.1 Akustik Kriptoanaliz

Tərif 13.1 (Akustik kriptoanaliz). *Akustik kriptoanaliz — mərkəzi prosessor (CPU), gərginlik requlyatorları və ya daxiletmə-xaricetmə qurğularının (klaviatura, printer) hesablama zamanı strukturdakı gərginlik dəyişmələrinə bağlı olaraq ətrafa yaydığı **yüksək tezlikli akustik dalğaları (ultrasəsləri)** xüsusi mikrofonlarla qeydə alaraq gizli məlumatları və açarları bərpa edən hücum metodudur (Genkin et al., 2014).*

Mexanizmi: 2013-cü il təcrübələrində GnuPG RSA reallaşdırılmasından açar çıxarma xüsusi seçilmiş şifrəli mətnlər və akustik ölçmələrlə göstərilmişdi. Məsafə sensor və qurğudan asılı idi: parabolik mikrofonla metr səviyyəsi, bəzi telefon sınaqlarında isə daha yaxın məsafə istifadə olunurdu. Bu nəticə bütün CPU-lar və RSA reallaşdırmaları üçün universal deyil.

13.2 Soyuq yükləmə hücumu

Tərif 13.2 (Soyuq yükləmə hücumu). *Soyuq yükləmə hücumu — kompüter və ya ağıllı cihaz anlıq olaraq söndürüldükdən və ya yenidən başladıldıqdan sonra, əməliyyat yaddaşındakı (DRAM) kondensatorların tam boşalmaması səbəbindən remonentlik (məlumatın yaddaşda qalma) effektiindən istifadə edərək gizli kriptografik açarları fiziki olaraq oxumağa çalışan hücum üsuludur (Halderman et al., 2008).*

Fiziki İcra Addımları:

1. **Termal Sabitləşdirmə:** İşlək vəziyyətdə olan cihazın yaddaş modulları (RAM) xüsusi soyuducu qazlar (məsələn, maye azot və ya sıxılmış hava aerosolu) vasitəsilə təxminən -50°C ilə -100°C aralığına qədər dondurulur. Bu fiziki soyutma yaddaş hüceyrələrindəki elektrik yüklərinin sızma sürətini azaldır və remonentlik müddətini bir neçə saniyədən bir neçə dəqiqəyə (bəzən saata) qədər uzadır.
2. **Fiziki köçürmə:** Cihazın enerjisi anlıq kəsilir, RAM modulları sürətlə yerindən çıxarılır və hücumçunun nəzarətində olan xüsusi proqram təminatlı digər bir kompüterə taxılır.
3. **Yaddaşın Sürətinin Çıxarılması:** Hücumçu cihazı öz xüsusi yükləmə diski (məsələn, yüngül Linux nüvəsi) ilə başladaraq RAM-in xalis məzmununu xarici daşıyıcıya köçürür və daxildəki AES, RSA açarlarının struktur izlərini tapır.

13.3 Optik Hücumlar

Tərif 13.3 (Optik hücum). *Mikroşxemin fiziki səthini mikroskoplar, infraqırmızı kameralar və ya lazer şüaları vasitəsilə vizual və ya fotonik olaraq təhlil edərək daxili registrlərin vəziyyətini oxumağa çalışan hücum üsuludur.*

- **Passiv Optik Analiz:** Emissiya mikroskopiyası (EMMI) vasitəsilə tranzistorların kommutasiya zamanı yaydığı görünməz foton sızıntılarının şəklini çəkməklə daxili məlumat axınını müəyyən etmək.
- **Aktiv Optik Analiz:** Çipin daxili yarımkeçirici silisium təbəqəsinə yönəldilmiş dəqiq fokuslu lazer impulsları ilə müəyyən məntiqi qapılarda anlıq foto-cərəyan yaradaraq bit çevrilməsi xətası törətmək (lazer xəta inyeksiyası).

14 Yan Kanal Hücumlarına Qarşı Sistem Səviyyəli Müdafiə

14.1 Aparat Səviyyəsində Müdafiə

- **Faraday Qəfəsi və Ekranlaşdırma:** Elektromaqnit sızıntılarını (EMA) minimuma endirmək üçün çipin və ya bütün ana lövhənin xüsusi metal izolyasiya qatları ilə örtülməsi.
- **Daxili Gərginlik Filtrləri:** Enerji sızıntılarını (SPA/DPA) boğmaq üçün çip daxilində inteqrasiya edilmiş xüsusi kondensatorlar və gərginlik tənzimləyiciləri vasitəsilə istehlak edilən ümumi cərəyan profilinin düzləşdirilməsi.
- **Təsadüfi saat tərəddüdü:** İcra izlərini zaman oxunda sürüşdürərək sadə hizalamanı çətinləşdirə bilər. Sinyal emalı ilə izlər yenidən hizalana bildiyi üçün bu, maskalama və başqa müdafiələri əvəz etmir.

- **İkiyollu Diferensial Məntiq Qapıları:** Bit və onun tamamlayıcısını iki fiziki yol ilə emal etməklə enerji profilini balanslaşdırmağa çalışır. Marşrut asimetriyası, keçid xətası və proses variasiyası qalıq sızıntı yarada bilər; sabit enerji sərfi zamanəti deyil.

14.2 Proqram Səviyyəsində Müdafiə

1. **Sabit Zamanlı Müqayisə Alqoritmləri :** Gizli açarların və ya heş dəyərlərinin yoxlanılması zamanı (məsələn, HMAC təsdiqlənməsi) standart sətir müqayisəsi ilk səhv bitdə dayandığı üçün vaxt sızıntısı yaradır. Bunun qarşısını almaq üçün bit səviyyəli XOR ($\oplus$) və OR ($\vee$) operatorlarına əsaslanan sabit zamanlı riyazi müqayisə modeli tətbiq olunur.

Konseptual Model: Eyni uzunluqlu A və B massivləri üçün kifayət qədər geniş unsigned accumulator seçilir və $R[i] = A[i] \oplus B[i]$ bütün indekslər üzrə hesablanır; sonda $R = 0$ yoxlanılır. OR accumulator toplamadakı overflow problemini daşıyır. Bunun həqiqətən sabit-zamanlı olub-olmadığı kompilyatorun yaratdığı maşın kodu və hədəf platforma üzrə yoxlanmalıdır; uzunluq adətən ictimai parametrlə olmalıdır.

2. **Kriptografik Maskalama və Körləşdirmə:** Daxili dəyişənlərin və dərəcələrin təsadüfi ədədlərlə ($x \oplus r$ və ya $d + k\varphi(n)$) modifikasiyası.
3. **Əməliyyatların Qarışdırılması:** Müstəqil funksiyaların və ya keş yaddaş cədvəllərinin oxunma ardıcılığının hər icrada təsadüfi permütasiya ilə qarışdırılması.

14.3 Kriptografik Protokol Səviyyəsində Müdafiə

- **Dinamik Yenidən Açarlama:** Eyni açar altında toplanan izlərin sayını məhdudlaşdırma bilər, lakin tələb olunan iz sayı hücum və sızıntı modelindən asılıdır; açarın dəyişdirilməsi mövcud izləri və əsas açar sızıntısını aradan qaldırmır.
- **Müvəqqəti Açarların İstifadəsi:** Düzgün yaradılan və silinən sessiya açarları uzunmüddətli açarın sonrakı kompromatının təsirini azalda bilər. Sessiya sirri, RNG və ya reallaşdırma sızarsa keçmiş trafik yenə riskə düşə bilər.
- **Sessiya Limitləri və Orakıl Bloklanması:** Eyni açarla icra olunan uğursuz cəhdlərin və ya xətalı şifrəli mətn sorğularının sayının protokol səviyyəsində sərt şəkildə məhdudlaşdırılması.

15 Yan Kanal Hücumlarının Müqayisəli Analizi

Mühazirə boyu keçdiyimiz hücum metodlarının xüsusiyyətlərini, tələb olunan resurs mürəkkəbliyini və hədəf sızıntı mənbələrini sistemləşdirmək üçün aşağıdakı analitik müqayisə cədvəli hazırlanmışdır.

Hücum Növü	Sızıntı Mənbəyi	Resurs Mürəkkəbliyi	Fiziki Məsafə (Ölçətanlıq)	Əsas Müdafiə Strategiyası
Vaxt Hücumu	İcra müddəti	Modeldən asılı	Yerli və ya uzaqdan, siqnal-küy nisbətindən asılı	Sabit-zamanlı kod və ölçmə

Hücum Növü	Sızıntı Mənbəyi	Resurs Mürəkkəbliyi	Fiziki Məsafə (Ölçətlilik)	Əsas Müdafiə Strategiyası
SPA	Birbaşa enerji istehlakı	Qurğudan asılı	Adətən yaxın/-fiziki ölçmə	Əməliyyat simmetriyası və sızıntı testi
DPA	Statistik enerji sızıntısı	İz sayı və modeldən asılı	Adətən yaxın/-fiziki ölçmə	Düzgün maskalama və sızıntı testi
EMA	Elektromaqnit şüalanma	Sensor və qurğudan asılı	Təməssiz, məsafə qurğudan asılı	Ekranlaşdırma, yerləşim və sızıntı testi
Keş Hücumları	Keş yaddaş müraciət zamanı	Orta	Yerli (Mikroarxitektura)	Cədvəllərin ləğvi, <i>Bit dilimləmə</i>
Xəta İn-yeksiyası Hücumları	Aparatın hesablama xətası	Xəta üsulundan asılı	Adətən fiziki və ya yaxın təsir	İnvariant/artıqlıq və çıxış yoxlaması
Akustik Analiz	CPU/Komponent ultrasəsləri	Yüksək	Lokal (Mikrofon məsafəsi)	Akustik səsboğucular, sabit cərəyan çəkimi
Soyuq Yükləmə	RAM remonenti (yük qalıqı)	Yüksək	Yerli (Fiziki müdaxilə)	Yaddaşın avtomatik silinməsi, RAM şifrələməsi

16 Praktik Layihələndirmə Təvsiyələri

Sistem və Program Səviyyəsində Yan Kanal Təhlükəsizliyi

• Təhlükəsiz Programlaşdırma Prinsipləri :

- Gizlidən asılı budaq və yaddaş müraciətlərindən qaçın; yoxlanmış sabit-zamanlı kitabxana API-si istifadə edin və nəticə məşin kodunu hədəf platformada test edin.
- Gizlidən asılı indeksli S-qutusu axtarışlarından qaçın. Platformaya uyğun bit dilimləmə, aparat AES və ya sabit-zamanlı səpələmə/yığıma kimi yoxlanmış yanaşma seçin.
- **Bit Dilimləmə** : Cədvəl müraciətlərini bit səviyyəli məntiq əməliyyatları ilə əvəz edə və keş-vaxt səthini azalda bilər. Performans və başqa mikroarxitektura sızıntılar platforma üzrə ölçülməlidir.

• Aparat Səviyyəsində Təhlükəsizlik :

- Dual-rail logic, gərginlik tənzimləyicisi və ekranlaşdırmanı təhdid modelinə uyğun qatlar kimi qiymətləndirin; heç biri təkbaşına sabit cərəyan zamanəti vermir.
- Təsədüfi saat tərəddüdü izlərin hizalanmasını çətinləşdirə bilər, lakin statistik yenidən hizalamaya davamlı əsas müdafiə kimi qəbul edilməməlidir.
- Elektromaqnit radiasiyasını lokallaşdırmaq üçün çip səviyyəsində fiziki ekranlaşdırma qatlarını tətbiq edin.

• Sertifikatlaşdırılmış Kitabxanalar və Modullar:

- Sıfırdan kriptografiya yazmaq əvəzinə, seçilmiş platforma və versiya üçün yan-kanal xüsusiyyətləri sənədləşdirilmiş libsodium, BearSSL və ya OpenSSL API-lərindən istifadə edin; kitabxana adı bütün konfigurasiyalar üçün avtomatik zəmanət deyil.
- Kritik açarların saxlanması və əməliyyatların aparılması üçün xüsusi fiziki qorunmaya malik **HSM** (aparat təhlükəsizlik modulu) və ya **TPM** (etibarlı platforma modulu) çiplərinə üstünlük verin.

• Test və Verifikasiya Alətləri:

- **dudect**: Kodun sabit zamanlı olub-olmadığını diferensial sınaq metodu və *t*-sınağı statistikası ilə yoxlayan effektiv təhlil aləti.
- **ctgrind**: Valgrind platforması üzərində işləyən və gizli açardan asılı olan yaddaş müraciətlərini və budaqlanmaları aşkarlayan test modulu.
- **ChipWhisperer**: Avadanlıq səviyyəsində real SPA, DPA və xəta inyeksiyası hücumlarını simulyasiya edən və aparatın dözümlülüyünü yoxlayan açıq qaynaqlı laboratoriya platforması.

17 Nümunə Məsələlər və Çalışmalar

Cəhddən əvvəl

Əvvəlcə hücumçunun müşahidəsini, fərziyyəni və ölçülən signalı ayırın; sonra müdafiə seçin. Müəllim üçün cavab açarı yalnız ilkin cəhddən sonra açılmalıdır.

Çalışma 17.1. *Tam axtarış hücumu ilə 40-bitlik gizli açarı tapmaq üçün ehtimal nəzəriyyəsinə görə orta hesabla neçə sınaq lazımdır?*

Çalışma 17.2. *Klassik kriptanaliz metodlarından olan Diferensial və Xətti kriptanaliz arasında 3 əsas konseptual fərqi sadalayın.*

Çalışma 17.3. *"Kvadratlaşdır-vur" alqoritminin sadə reallaşdırması niyə vaxt hücumlarına və SPA-ya qarşı kritik dərəcədə həssasdır? Bu həssaslığı azaldan sabit-zamanlı riyazi yanaşmanı alqoritmik olaraq təsvir edin.*

Çalışma 17.4. *Sadə Enerji Analizi (SPA) ilə Diferensial Enerji Analizi (DPA) arasındakı fundamental fərqlər hansılardır?*

Çalışma 17.5. *Mikroarxitektura yan kanal hücumlarından olan Prime+Probe keş hücumunun üç mərhələ üzrə işləmə mexanizmini şərh edin.*

Çalışma 17.6. *RSA-CRT (Çin Qalıqlar Teoremi əsaslı RSA) imzalama strukturuna qarşı icra olunan Bellcore xəta inyeksiyası hücumunun riyazi prinsipini və sızıntı tənliyini göstərin.*

Çalışma 17.7. *AES alqoritminin proqram təminatında axtarış cədvəlləri və T-cədvəlləri vasitəsilə icra edilməsi niyə keş yaddaş hücumlarına şərait yaradır?*

Çalışma 17.8. *Yan kanal sızıntılarının qarşısını proqram təminatı səviyyəsində almaq üçün tətbiq edilən 3 əsas müdafiə strategiyasını sadalayın.*

18 Müəllim üçün cavab açarı

1. 40-bitlik bir açar fəzasında ümumi mümkün variantların sayı 2^{40} -dir. Tam axtarış hücumunda açarın ortalama tapılma müddəti (uğurlu ehtimalın orta qiyməti) riyazi olaraq ümumi fəzanın yarısına bərabərdir:

$$\frac{2^{40}}{2} = 2^{39} \approx 5.49 \times 10^{11} \text{ sınaq.}$$

2. Diferensial və xətti kriptanaliz arasındakı 3 əsas fərq:

1. **Məlumat növü:** Diferensial kriptanaliz hücumçudan seçilmiş açıq mətn tələb etdiyi halda, xətti kriptanaliz yalnız məlum açıq mətn əsasında icra oluna bilər.
2. **Riyazi əsas:** Diferensial analiz giriş və çıxış XOR fərqlərinin yayılma ehtimallarına ($\Delta X \rightarrow \Delta Y$), xətti analiz isə qeyri-xətti komponentlərin (S-Box) xətti tənliklərlə aproksimasiya (yaxınlaşma) meylinə əsaslanır.
3. **Hədəf strukturu:** Diferensial analiz daha çox blok şifrələrinin daxili diffuziyasını sındırmağa yönəlir, xətti analiz isə qapalı daxili bitlərin xətti korrelyasiyasını tapmağa fokuslanır.

3. Sadə kvadrat yüksəlt və vur alqoritmində gizli dərəcənin cari bit 0 olduqda dövr daxilində yalnız bir dərəcəyə yüksəltmə ($R \times R$) icra olunur, lakin bit 1 olduqda əlavə olaraq vurma ($R \times g$) əməliyyatı da yerinə yetirilir. Bu asimmetriya həm icra müddətində (vaxt hücumu), həm də cərəyan istehlakında (SPA) kəskin vizual fərqlər sızdırır.

Sabit Zamanlı Həll (Alqoritmik Təsvir): Budaqlanmanı ləğv etmək üçün hər bir bitdən asılı olmayaraq həm kvadrat, həm də vurma əməliyyatları mütləq icra edilməlidir. Əgər bit 0-dırsa, vurmanın nəticəsi saxta/müvəqqəti bir $Saxta_R$ dəyişəninə mənsub edilir:

1. Dövr daxilində hər bir bit üçün:
2. $R \leftarrow (R \times R) \pmod{p}$
3. $Mvqqti_R \leftarrow (R \times g) \pmod{p}$
4. **Şərt əvəzinə bit maskası ilə mənsubetmə:** $R \leftarrow (\text{bit} \times Mvqqti_R) + ((1 - \text{bit}) \times R)$

Bu struktur gizli bitdən asılı əməliyyat sayını bərabərləşdirir, lakin maskalı seçim compiler tərəfindən budağa çevrilə bilər və multiply/reduction mikroarxitektura olaraq dəyişən zamanlı ola bilər. Buna görə sabit-zamanlı primitive və maşın-kod yoxlaması tələb olunur; eyni enerji sərfi ayrıca təmin edilmir.

4. SPA bir və ya az sayda enerji izində seçilən əməliyyat nümunələrindən istifadə edir. DPA/CPA isə çoxsaylı izdə sızıntı hipotezini statistik yoxlayır; tələb olunan iz sayı və küyə davamlılıq qurğu, model və əks-tədbirlərdən asılıdır.
5. *Prime+Probe* hücumunun iş mexanizmi 3 mərhələdən ibarətdir:

1. **Prime (Doldurma):** Hücumçu hədəf keş setlərini özünün mənasız verilənləri ilə tamamilə doldurur və keşi nəzarətə götürür.
2. **İcra:** Qurban proqramın kriptografik əməliyyatı icra etməsi gözlənilir. Əgər qurban hədəf setə müraciət edərsə, hücumçunun verilənlərini oradan sıxışdırıb çıxarır.

3. **Yoxlama (Yoxlama):** Hücümçü öz verilənlərini yenidən oxuyub zamanı ölçür. Gecikmə seçilmiş keş set-də qurban aktivliyinə dair statistik signal verir; tək ölçmə konkret ünvan girişinin qəti sübutu deyil.
6. RSA-CRT strukturunda imzalama zamanı p moduluna aid olan s_1 qolunun hesablanması xəta törədilərsə, səhv $\hat{s}_1$ alınır, lakin q moduluna aid s_2 qolu düzgün hesablanır. CRT birləşməsindən sonra əldə edilən səhv $\hat{s}$ imzası üçün Bellcore sızıntı düsturu belə qurulur:

$$\gcd(\hat{s}^e - m, n) = q$$
 Burada $\hat{s}^e - m$ fərqi q -yə tam bölündüyü, lakin p -yə bölünmədiyi üçün bir GCD hesablanması modulun gizli q vuruğunu, sonra isə $p = n/q$ dəyərini verir.
7. Bəzi proqram AES reallaşdırmaları əməliyyatları T-cədvəllərində birləşdirir və cədvəl indeksi açardan asılı olur. Keş müşahidələri indeks barədə statistik məlumat sızdırır və kifayət qədər ölçmə/model ilə açar namizədlərini daralda bilər. Hücümün praktikliyi keş paylaşımı, planlaşdırıcı, müdafiələr və reallaşdırmadan asılıdır.
8. Proqram təminatı səviyyəsində 3 fundamental müdafiə üsulu:

1. **Sabit zamanlı reallaşdırma :** Şerti keçidləri və yaddaş müraciətlərini zamandan asılı olmayan riyazi strukturlara çevirmək.
2. **Kriptoqrafik maskalama :** Daxili bütün həssas aralıq dəyişənləri hər əməliyyatda təsadüfi bir r maskası ilə $(x \oplus r)$ gizlətmək.
3. **Bit Dilimləmə :** Bütün cədvəl müraciətlərini ləğv edərək məlumatları bit səviyyəli parallel məntiqi qapı zəncirləri ilə emal etmək.

19 Xülasə və Yekun Nəticələr

Bu mühazirə çərçivəsində kriptoqrafik sistemlərin təhlükəsizlik mühitini tamamilə fərqli bir perspektivdən — riyazi abstraksiyadan fiziki reallığa keçid müstəvisində araşdırdıq. Sənəd boyu öyrənilən fundamental anlayışların xülasəsi aşağıdakı kimidir:

- **Klassik kriptoqrafik hücumlar:** Alqoritmlərin daxili riyazi və məntiqi zəifliklərini hədəf alan diferensial, xətti və tam axtarış kriptoanaliz üsullarının iş prinsipləri sənədləşdirilmişdir (Biham and Shamir, 1993; Matsui, 1994a).
- **Yan Kanal Hücumlarının Təbiəti:** Bu hücum növünün alqoritmin riyazi gücünə deyil, onun fiziki aparat və ya proqram təminatı səviyyəsindəki reallaşdırılması zamanı ətrafa sızdırdığı fiziki parametrlərə (vaxt, cərəyan, şüalanma) əsaslandığı nümayiş etdirilmişdir (Kocher, 1996).
- **Vaxt hücumları:** Gizli verilənlərdən asılı icra müddətinin açar sızıntısına yol açma bilməsi və sabit-zamanlı proqramlaşdırmanın digər sistem əks-tədbirləri ilə birlikdə əsas müdafiələrdən biri olduğu göstərilmişdir (Kocher, 1996).
- **Enerji istehlakı analizi:** Bir və ya az sayda izin görünən xüsusiyyətlərindən istifadə edə bilən SPA ilə çoxsaylı iz üzərində statistik fərziyyə yoxlayan DPA fərqləndirilmişdir. İz sayı qurğu, model və küydən asılıdır; maskalama yalnız düzgün tətbiq və sınaqla müdafiə qatına çevrilir (Kocher et al., 1999; Mangard et al., 2007).

- **Elektromaqnit İzləmə Hücumlari (EMA):** Cihazların daxili komponentlərinin keçirdiyi cərəyanın yaratdığı təməssiz sızıntılar və distansion təhlükələr araşdırılmış, TEMPEST standartları çərçivəsində ekranlaşdırma texnikalarına toxunulmuşdur (Mangard et al., 2007).
- **Mikroarxitektur Keş Hücumlari:** *Prime+Probe* və *Flush+Reload* kimi metodlarla prosessorun keş yaddaş statusundan gizli məlumatların bərpası prinsipləri öyrənilmiş, program səviyyəsində sabit-zamanlı cədvəl müraciətləri və bit dilimləmə metodologiyasının əhəmiyyəti vurğulanmışdır (Bernstein, 2005).
- **Xəta İnveksiya Hücumlari :** DFA və RSA-CRT Bellcore modelinin riyazi fəsadları təhlil edilmişdir. RSA-CRT üçün səhv imzanı buraxmazdan əvvəl açıq açarla yoxlama və ya sübut olunmuş xəyata davamlı CRT əsas müdafiədir; korlaşdırma vaxt/enerji üçün faydalı olsa da bu yoxlamayı əvəz etmir (Boneh et al., 1997; Biham and Shamir, 1997).
- **Qeyri-Klassik Fiziki Hücumlari:** Akustik (ultrasəs), soyuq yükləmə və optik analiz kimi cihazın yerləşdiyi fiziki mühitin təsirinə əsaslanan qabaqcıl yan kanal hücumlarının iş prinsipləri ümumiləşdirilmişdir (Genkin et al., 2014; Halderman et al., 2008).

Əsas Nəticə: Kriptoqrafik sistemin təhlükəsizliyi yalnız primitivin nəzəri açar ölçüsü ilə ölçülmür. Reallaşdırma sızıntısı və xəta inyeksiya modeli nəzəri axtarış sərhədindən yan keçə bilər, lakin praktiki xərc cihaz və hücum imkanlarından asılıdır. Müdafiə təhdid modeli, yoxlanmış sabit-zamanlı kod, düzgün maskalama/xəta inyeksiya yoxlaması, aparat qatları və empirik sızıntı sınağının birlikdə tətbiqini tələb edir.

References

- D. J. Bernstein. Cache-timing attacks on aes. In *ECRYPT Workshop*, 2005. <https://cr.yp.to/antiforgery/cachetiming-20050414.pdf>.
- E. Biham and A. Shamir. *Differential Cryptanalysis of the Data Encryption Standard*. Springer, New York, 1993.
- E. Biham and A. Shamir. Differential fault analysis of secret key cryptosystems. In *Advances in Cryptology - CRYPTO '97*, volume 1294 of *Lecture Notes in Computer Science*, pages 513–525. Springer, 1997. doi: 10.1007/BFb0052259.
- D. Boneh, R. A. DeMillo, and R. J. Lipton. On the importance of checking cryptographic protocols for faults. In *Advances in Cryptology - EUROCRYPT '97*, volume 1233 of *Lecture Notes in Computer Science*, pages 37–51. Springer, 1997. doi: 10.1007/3-540-69053-0_4.
- ElectronicFrontierFoundation. *Cracking DES: Secrets of Encryption Research, Wiretap Politics & Chip Design*. O'Reilly Media, Sebastopol, 1998.
- D. Genkin, A. Shamir, and E. Tromer. Rsa key extraction via low-bandwidth acoustic cryptanalysis. In *Advances in Cryptology - CRYPTO 2014*, volume 8616 of *Lecture Notes in Computer Science*, pages 444–461. Springer, 2014. doi: 10.1007/978-3-662-44371-2_25.
- J. A. Halderman, S. D. Schoen, N. Heninger, W. Clarkson, W. Paul, J. A. Calandrino, A. J. Feldman, J. Appelbaum, and E. W. Felten. Lest we remember: Cold boot attacks on encryption keys. In *USENIX Security Symposium*, pages 45–60, 2008. https://www.usenix.org/legacy/events/sec08/tech/full_papers/halderman/halderman.pdf.

- P. C. Kocher. Timing attacks on implementations of Diffie-Hellman, RSA, DSS, and other systems. In *Advances in Cryptology — CRYPTO '96*, volume 1109 of *Lecture Notes in Computer Science*, pages 104–113. Springer, 1996. doi: 10.1007/3-540-68697-5_9.
- P. C. Kocher, J. Jaffe, and B. Jun. Differential power analysis. In *Advances in Cryptology - CRYPTO '99*, volume 1666 of *Lecture Notes in Computer Science*, pages 388–397. Springer, 1999. doi: 10.1007/3-540-48405-1_25.
- S. Mangard, E. Oswald, and T. Popp. *Power Analysis Attacks: Revealing the Secrets of Smart Cards*. Springer, New York, 2007. ISBN: 978-0387308579.
- M. Matsui. Linear cryptanalysis method for des cipher. In *Advances in Cryptology — EURO-CRYPT '93*, volume 765 of *Lecture Notes in Computer Science*, pages 386–397. Springer, 1994a.
- M. Matsui. The first experimental cryptanalysis of the data encryption standard. *Advances in Cryptology — CRYPTO '94*, pages 1–11, 1994b.
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.